

Esquemas Simétricos e Assimétricos

Confidencialidade e Autenticidade em Criptografia

Segurança Informática — Introdução à Criptografia e aos Protocolos Criptográficos

Objetivos de Aprendizagem

Ao final deste tema, o aluno deve ser capaz de:

- Distinguir **criptografia simétrica** de **criptografia assimétrica** e identificar as propriedades de cada paradigma
- Explicar como cada tipo de esquema pode garantir **confidencialidade**
- Explicar como cada tipo de esquema pode garantir **autenticidade** (autenticação de origem e integridade)
- Reconhecer as vantagens, limitações e cenários de uso de cada abordagem
- Compreender a motivação para **esquemas híbridos**

[*PROFUNDIDADE ASSUMIDA*] — a FUC não detalha o nível de profundidade exato; assume-se nível introdutório/conceitual adequado a uma UC teórico-prática de licenciatura.

Confidencialidade vs. Autenticidade

Antes de comparar simétrico/assimétrico, é essencial separar dois objetivos de segurança distintos:

- **Confidencialidade:** garantir que apenas o destinatário legítimo consegue ler a informação. Obtém-se por **cifra (encryption)**.
- **Autenticidade:** garantir que a mensagem provém de quem diz provir e que **não foi alterada** (integridade + autenticação de origem). Obtém-se por **códigos de autenticação de mensagem (MAC)** ou **assinaturas digitais**.

Um esquema pode garantir um destes objetivos, ambos, ou nenhum — cifrar não implica autenticar, e vice-versa.

Criptografia Simétrica — Conceito

- Usa **uma única chave secreta (K)**, partilhada entre emissor e recetor, tanto para cifrar como para decifrar
- A segurança depende inteiramente do **sigilo da chave** — se K for comprometida, todo o canal é comprometido
- Operações tipicamente **rápidas e eficientes**, adequadas a grandes volumes de dados
- **Desafio principal:** distribuição segura da chave entre as partes antes de qualquer comunicação (*key distribution problem*)

Emissor: $C = E(K, M)$ Recetor: $M = D(K, C)$

Onde **M** = mensagem original, **C** = criptograma, **E/D** = funções de cifra/decifra.

Criptografia Simétrica — Tipos de Cifras

Cifras de bloco (block ciphers)

- Operam sobre blocos de tamanho fixo (ex.: 128 bits)
- Exemplo de referência: **AES** (Advanced Encryption Standard) [FONTE EXTERNA]
- Necessitam de um **modo de operação** para cifrar mensagens maiores que um bloco (ex.: CBC, CTR, GCM)

Cifras de fluxo (stream ciphers)

- Cifram a mensagem bit a bit / byte a byte, combinando-a com um fluxo de chave (*keystream*)
- Adequadas a comunicação em tempo real (ex.: streaming, voz)

```
# Exemplo conceptual de cifra simétrica com AES (modo GCM)
from cryptography.hazmat.primitives.ciphers.aead import AESGCM

chave = AESGCM.generate_key(bit_length=128)
aesgcm = AESGCM(chave, )
nonce = os.urandom(12)
criptograma = aesgcm.encrypt(nonce, b"mensagem secreta", None)
```

Confidencialidade com Esquemas Simétricos

- O emissor cifra a mensagem com a chave partilhada **K**: $C = E(K, M)$
- O recetor, possuindo a mesma **K**, decifra: $M = D(K, C)$
- **Garantia obtida**: apenas quem possui **K** consegue obter **M** a partir de **C**
- **Limitação**: não garante, por si só, **autenticidade** — um atacante sem conhecer **K** pode ainda assim alterar **C** em trânsito, e o recetor pode decifrar "lixo" sem se aperceber da alteração (a menos que o modo de operação inclua autenticação, como o **GCM**)

Cifrar **não é o mesmo** que autenticar — é um erro comum assumir que confidencialidade implica integridade.

Autenticidade com Esquemas Simétricos: MAC

- Um **MAC (Message Authentication Code)** é um valor calculado a partir da mensagem **e** de uma chave secreta partilhada
- Permite ao recetor verificar simultaneamente:
 - **Integridade**: a mensagem não foi alterada

- **Autenticidade de origem:** só quem possui a chave pode ter gerado o MAC válido
- Construção comum: **HMAC**, baseado numa função de hash (ex.: HMAC-SHA256) [FONTE EXTERNA]

```
Emissor:  T = MAC(K, M)          envia (M, T)
Recetor:  T' = MAC(K, M)         aceita se T' == T
```

- **Não garante confidencialidade** — **M** viaja em claro, a menos que combinado com cifra (ex.: *Encrypt-then-MAC*)

Criptografia Assimétrica — Conceito

- Usa um **par de chaves matematicamente relacionadas**: uma **chave pública** (divulgável) e uma **chave privada** (mantida em sigilo pelo dono)
- O que é cifrado com uma das chaves só pode ser decifrado com a outra
- Resolve o problema de **distribuição de chaves** dos esquemas simétricos: não é necessário partilhar nenhum segredo antecipadamente
- **Custo computacional muito superior** ao da criptografia simétrica — normalmente usada para pequenas quantidades de dados (chaves, *hashes*) e não para cifrar grandes volumes diretamente

Exemplos de referência: **RSA**, **criptografia de curva elíptica (ECC)** [FONTE EXTERNA]

Confidencialidade com Esquemas Assimétricos

- O emissor cifra com a **chave pública** do recetor: **C** = **E**(PubB, M)
- Só o recetor, possuindo a correspondente **chave privada**, consegue decifrar: **M** = **D**(PrivB, C)
- **Vantagem:** o emissor não precisa de partilhar nenhum segredo previamente com o recetor — basta conhecer a sua chave pública
- **Limitação prática:** devido ao custo computacional, raramente se usa diretamente para cifrar mensagens longas

```
# Exemplo conceptual – cifra com RSA (chave pública do destinatário)
criptograma = chave_publica_B.encrypt(
    mensagem,
    padding.OAEP(mgf=padding.MGF1(algorithm=hashes.SHA256()),
                 algorithm=hashes.SHA256(), label=None)
)
```

Autenticidade com Esquemas Assimétricos: Assinatura Digital

- O emissor assina com a sua **chave privada**: **S** = **Sign**(PrivA, M)
- Qualquer recetor pode verificar usando a **chave pública** do emissor: **Verify**(PubA, M, S) → {válido, inválido}
- **Garantias obtidas:**

- **Autenticidade de origem:** só o detentor de **PrivA** pode produzir uma assinatura válida
- **Integridade:** qualquer alteração de **M** invalida **S**
- **Não-repúdio:** o emissor não pode negar ter assinado, pois só ele possui **PrivA** (propriedade que o MAC simétrico **não** oferece, já que a chave é partilhada)

Note-se a **simetria invertida** face à confidencialidade: para cifrar usa-se a chave pública do *destinatário*; para assinar usa-se a chave privada do *emissor*.

Esquemas Híbridos

Na prática, simétrico e assimétrico são **combinados**, aproveitando o melhor de cada paradigma:

1. Gera-se uma **chave de sessão simétrica** aleatória (rápida para grandes volumes)
 2. A chave de sessão é **cifrada com criptografia assimétrica** (chave pública do destinatário) e enviada junto com a mensagem
 3. A mensagem é **cifrada com a chave de sessão**, usando um esquema simétrico eficiente
 4. O destinatário usa a sua chave privada para recuperar a chave de sessão, e depois decifra a mensagem
- Resolve o problema de distribuição de chaves **sem** pagar o custo computacional de cifrar tudo com criptografia assimétrica
 - Base de protocolos como **TLS** [FONTE EXTERNA]

Comparação: Simétrico vs. Assimétrico

Critério	Simétrico	Assimétrico
Nº de chaves	1 chave partilhada	par chave pública/privada
Velocidade	Rápido	Lento (ordens de grandeza)
Distribuição de chave	Problemática (canal seguro prévio)	Simples (chave pública divulgável)
Confidencialidade	Cifra com K	Cifra com chave pública do recetor
Autenticidade	MAC (com K)	Assinatura digital (com chave privada)
Não-repúdio	Não oferece	Oferece
Uso típico	Grandes volumes de dados	Troca de chaves, assinaturas, identidade

Síntese — Pontos-Chave

- **Confidencialidade ≠ Autenticidade:** são objetivos de segurança distintos, obtidos por mecanismos diferentes
- **Simétrico:** uma chave partilhada; **rápido**; problema de distribuição; confidencialidade via cifra, autenticidade via **MAC**
- **Assimétrico:** par de chaves pública/privada; **lento**; resolve a distribuição de chaves; confidencialidade via cifra com a chave pública do destinatário, autenticidade via **assinatura digital** com não-repúdio
- Sistemas reais usam **esquemas híbridos:** assimétrico para trocar uma chave de sessão, simétrico para cifrar o conteúdo

- A escolha do esquema depende do **objetivo de segurança pretendido** e das **restrições de desempenho** do sistema
-

Glossário

- **Confidencialidade:** propriedade que garante que a informação só é acessível a entidades autorizadas
- **Autenticidade:** garantia de que uma mensagem provém de uma origem legítima e não foi alterada
- **Cifra simétrica:** esquema criptográfico com uma única chave partilhada para cifrar e decifrar
- **Cifra assimétrica:** esquema criptográfico com par de chaves pública/privada
- **MAC:** código que combina mensagem e chave secreta para garantir integridade e autenticação de origem
- **Assinatura digital:** mecanismo assimétrico que garante autenticidade, integridade e não-repúdio
- **Não-repúdio:** propriedade que impede o emissor de negar a autoria de uma mensagem assinada
- **Esquema híbrido:** combinação de criptografia assimétrica (troca de chave) e simétrica (cifra de dados)